GRC REPORT

1. Business Impact

The organization is exposed to multiple security risks across email, endpoint, and network layers:

Operational Risk:

The Follina (CVE-2022-30190) exploit enables remote code execution, potentially allowing attackers to run arbitrary commands on user systems.

Credential Compromise Risk:

The phishing campaign impersonating Amazon is designed to harvest user credentials, which could lead to unauthorized access to internal systems.

Unauthorized Access Risk:

The RDP brute force attack targeting the administrator account demonstrates active attempts to gain privileged access to critical infrastructure.

Reputational Risk:

Successful exploitation or credential theft could lead to data breaches, impacting customer trust and organizational credibility.

2. Risk Level

Threat	Likelihood	Impact	Overall Risk
Follina Exploit	High	High	Critical
Phishing Attack	High	High	Critical
RDP Brute Force	High	Medium–High	High

Summary:

- Overall Risk Level: Critical
- Multiple active attack vectors indicate a broad attack surface exposure

3. Compliance Implications

Under General Data Protection Regulation:

- **Potential Personal Data Exposure:**
  - Phishing attacks may capture user credentials (personally identifiable information)
  - Successful system compromise could expose sensitive organizational or customer data
- **Breach Notification Requirement:**

    - If data access or exfiltration is confirmed, the organization may be required to report within 72 hours
- **Control Failures Identified:**
    - Lack of effective email filtering (phishing delivery)
    - Insufficient endpoint protection (exploit execution)
    - Weak authentication controls (brute force exposure)

4. Recommended Controls

A. Technical Controls

- **Patch Management**
    - Immediately patch systems vulnerable to Follina
    - Disable MSDT where not required
- **Email Security**
    - Implement advanced phishing detection and filtering
    - Enforce URL rewriting and sandboxing for links
- **Endpoint Protection**
    - Deploy Endpoint Detection & Response (EDR)
    - Monitor suspicious process chains:

      WINWORD.exe → msdt.exe

- **Access Control**
    - Enforce Multi-Factor Authentication (MFA) for RDP
    - Disable or rename default administrator account
    - Implement account lockout policies

B. Network Security Controls

- Restrict RDP access to trusted IP ranges
- Enable firewall rules to block suspicious external IPs
- Monitor abnormal login attempts (Event ID 4625 spikes)

C. Monitoring & Detection

- Centralized logging (SIEM)
- Alerting on:
    - Repeated failed logins
    - Suspicious email activity
    - Unusual process execution

D. Security Awareness & Training

- Conduct phishing awareness training for employees

- Educate users on:
    - Suspicious email indicators
    - Safe handling of attachments and links

Conclusion

The organization is currently facing multi-vector attack attempts targeting users, endpoints, and authentication systems.

Without immediate remediation and stronger controls, there is a high likelihood of:

- System compromise
- Credential theft
- Regulatory exposure

A defense-in-depth strategy combining technical controls, monitoring and user awareness is required to reduce overall risk.